

# Clase 235 — Respuesta a incidentes en la nube

Parte: **10 — Seguridad en la nube y contenedores** · Fuente: *NIST SP 800-61 Computer Security Incident Handling Guide* y *AWS Security Incident Response Guide* 🕒 Duración estimada: **130 min** · Nivel: **Avanzado**

## 🎯 Objetivo

Aplicar el ciclo de respuesta a incidentes (NIST SP 800-61) al contexto de la nube, donde la elasticidad, las APIs y la efimeridad cambian la práctica: contención por IAM y aislamiento de red, adquisición de evidencia mediante snapshots, y erradicación/recuperación aprovechando IaC. El alumno ejecutará un playbook completo sobre una credencial comprometida y una instancia comprometida.

## 📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Aplicar** las fases de NIST (preparación, detección/análisis, contención, erradicación, recuperación, lecciones) a la nube.
- 2. **Contener** una credencial comprometida y una instancia comprometida sin destruir evidencia.
- 3. **Adquirir** evidencia con snapshots, aislamiento y volcado de metadatos/logs.
- 4. **Erradicar y recuperar** usando IaC para reconstruir de forma limpia.
- 5. **Documentar** un playbook reutilizable y las lecciones aprendidas.

## 📖 Temas

| # | Tema                                   | Por qué importa                          |
|---|----------------------------------------|------------------------------------------|
| 1 | Ciclo NIST aplicado a la nube          | Marco común y probado                    |
| 2 | Preparación: roles, permisos, runbooks | La respuesta se gana antes del incidente |
| 3 | Contención de identidad                | Revocar/rotar credenciales y sesiones    |
| 4 | Aislamiento de recursos                | Cuarentena sin apagar la evidencia       |
| 5 | Adquisición de evidencia               | Snapshots, memoria, logs preservados     |
| 6 | Erradicación y recuperación con IaC    | Reconstruir limpio y reproducible        |
| 7 | Post-incidente y lecciones             | Cerrar el ciclo y mejorar                |

## 📖 Definiciones y características

- **Playbook/runbook:** procedimiento paso a paso para un tipo de incidente. *Clave:* reduce el tiempo de respuesta y errores bajo presión.
- **Contención:** limitar el alcance del incidente. *Clave:* en la nube suele empezar por IAM (revocar sesiones, deshabilitar claves).

- **Aislamiento (cuarentena):** apartar un recurso sin destruirlo. *Clave:* cambia security group a "sin tráfico" en vez de apagar, para conservar memoria.
- **Snapshot forense:** copia inmutable de un volumen/disco. *Clave:* evidencia sin alterar el original.
- **Rotación de credenciales:** invalidar y reemplazar secretos comprometidos. *Clave:* corta el acceso del atacante.
- **Erradicación:** eliminar la presencia del atacante (backdoors, usuarios, reglas). *Clave:* verifica que no queda persistencia.
- **Recuperación con IaC:** reconstruir desde código confiable. *Clave:* garantiza un estado limpio y auditable.

## Herramientas y preparación

- Cuenta de laboratorio con logging ya configurado (clase 234) y CLIs del proveedor.
- Herramientas de forense cloud como **AWS IR** playbooks, snapshots de EBS/discos y **Cloud Custodian** para automatizar contención.
- Un repositorio Terraform (clase 230) para reconstrucción.

```
# Contención de credencial: deshabilitar una clave de acceso comprometida (AWS)
aws iam update-access-key --access-key-id AKIA ... --status Inactive
# Adquisición: crear un snapshot forense del volumen de una instancia comprometida
aws ec2 create-snapshot --volume-id vol-0abc --description "IR-forense-caso-42"
```

## Laboratorio guiado

Ejecuta el playbook en tu **cuenta de laboratorio**, sobre recursos que controlas.

1. **Preparación:** define un rol de "responder" con permisos mínimos para aislar y adquirir; crea el runbook y una cuenta/bucket de evidencia.
2. **Detección/análisis:** parte de una alerta de la clase 234 (p. ej. creación anómala de clave de acceso). Reconstruye el "quién/qué/cuándo" con los logs del plano de gestión.
3. **Contención de identidad:** deshabilita la clave comprometida, revoca las sesiones activas (invalidar tokens) y aplica una policy de deny explícito al principal afectado. **No lo borres aún** (evidencia).
4. **Aislamiento del recurso:** para una instancia comprometida, cambia su security group a uno sin reglas (cuarentena) en lugar de apagarla, para preservar la memoria y las conexiones.
5. **Adquisición:** crea un **snapshot** del volumen, exporta los logs relevantes y guarda metadatos (etiquetas, IAM, red) en el bucket de evidencia inmutable.
6. **Erradicación:** identifica y elimina persistencia (usuarios/roles nuevos, claves, reglas, funciones backdoor). Verifica con los logs que no queda actividad del atacante.
7. **Recuperación:** reconstruye los recursos afectados **desde Terraform** en un estado limpio; rota todos los secretos que pudieran estar comprometidos.
8. **Post-incidente:** redacta el informe y las lecciones aprendidas; convierte los hallazgos en detecciones nuevas y en mejoras del hardening.

## Ejercicios

1. Escribe el runbook de "credencial IAM comprometida" con pasos y comandos.

2. Diseña el procedimiento de cuarentena de una instancia sin destruir evidencia.
3. Automatiza con Cloud Custodian el aislamiento de un recurso etiquetado como comprometido.
4. Redacta el procedimiento de adquisición de snapshots y cadena de custodia.
5. Reconstruye un recurso desde laC y verifica el estado limpio.
6. Convierte una lección aprendida en una regla de detección nueva.

## Reto verificable

Ejecuta un playbook completo end-to-end para una credencial comprometida que lanzó una instancia maliciosa: detección, contención, aislamiento, adquisición, erradicación y recuperación con laC.

**Criterio de aceptación:** al final, la clave comprometida está deshabilitada y sus sesiones revocadas, existe un snapshot forense y evidencia preservada en almacén inmutable, no queda persistencia del atacante (verificado en logs), y el recurso afectado está reconstruido desde Terraform con secretos rotados. Todo queda documentado en un informe con línea de tiempo.

## Errores comunes

| Síntoma / mensaje                            | Causa y cómo arreglar                                                         |
|----------------------------------------------|-------------------------------------------------------------------------------|
| Se apagó la instancia y se perdió la memoria | Contención destructiva prematura; aísla por red antes de apagar.              |
| El atacante volvió tras rotar una clave      | Quedó persistencia (otro usuario/rol/función); erradica antes de recuperar.   |
| Evidencia alterada o no admisible            | Se trabajó sobre el original; adquiere snapshots y mantén cadena de custodia. |
| Rotación incompleta de secretos              | Solo se rotó el secreto obvio; rota todos los que la identidad pudo tocar.    |
| Reconstrucción trae de vuelta el problema    | Se reconstruyó desde laC vulnerable; corrige el código antes de aplicar.      |

## Preguntas frecuentes

**? ¿Por qué aislar por red en vez de apagar una instancia comprometida?** Apagarla destruye la memoria volátil y las conexiones activas, evidencia valiosa. Aislarla (security group sin tráfico) la neutraliza conservando el estado para el análisis forense.

**? ¿Qué se contiene primero en la nube, la identidad o el recurso?** Normalmente la identidad: deshabilitar la credencial comprometida y revocar sesiones corta el acceso del atacante de inmediato, incluso a recursos que aún no sabes que tocó. Luego se aísla el recurso concreto.

**? ¿Por qué reconstruir con laC en lugar de "limpiar" el recurso?** Porque nunca tienes plena certeza de haber eliminado toda la persistencia de un sistema comprometido. Reconstruir desde código confiable garantiza un estado limpio, reproducible y auditable.

## Referencias

---

- NIST SP 800-61 Rev. 2, Computer Security Incident Handling Guide.  
<https://csrc.nist.gov/pubs/sp/800/61/r2/final>
- AWS Security Incident Response Guide. <https://docs.aws.amazon.com/security-ir/latest/userguide/welcome.html>
- MITRE ATT&CK — Cloud Matrix. <https://attack.mitre.org/matrices/enterprise/cloud/>
- Cloud Custodian. <https://cloudcustodian.io/>
- Microsoft — Incident response in the cloud.  
<https://learn.microsoft.com/security/operations/incident-response-overview>

## Siguiente clase

---

Clase 236 - Secure SDLC y filosofia shift-left